

Rapport d'Audit Technique de Sécurité

Cible : 10.0.0.10 (Infrastructure ONGarde)

Date : 25 Juin 2026

Statut : Évaluation périmétrique terminée / En attente d'ouverture de flux

1. Synthèse de l'Audit Réseau

Les phases de reconnaissance active se sont heurtées à des configurations défensives restrictives au niveau du périmètre réseau (Pare-feu pfSense).

- **Filtrage Global Systématique :** Le scan réseau exhaustif ciblant l'intégralité des 65 535 ports TCP s'est conclu par un résultat uniforme : 100 % des ports sont identifiés comme filtered.
- **Analyse de la Politique :** Le pare-feu applique une politique stricte de type *Drop* (rejet silencieux des paquets), neutralisant la détection automatisée de services ou de versions.

```
(kali@kali)-[~]
$ nmap -Pn -p- --min-rate 2000 10.0.0.10
Starting Nmap 7.98 ( https://nmap.org ) at 2026-06-25 11:56 -0400
sendto in send_ip_packet_sd: sendto(5, packet, 44, 0, 10.0.0.10, 16) => Operation not permitted
Offending packet: TCP 192.168.230.128:45339 > 10.0.0.10:1947 S ttl=48 id=4791
1 iphlen=44 seq=890391950 win=1024 <mss 1460>
Nmap scan report for 10.0.0.10
Host is up.
All 65535 scanned ports on 10.0.0.10 are in ignored states.
Not shown: 65535 filtered tcp ports (no-response)

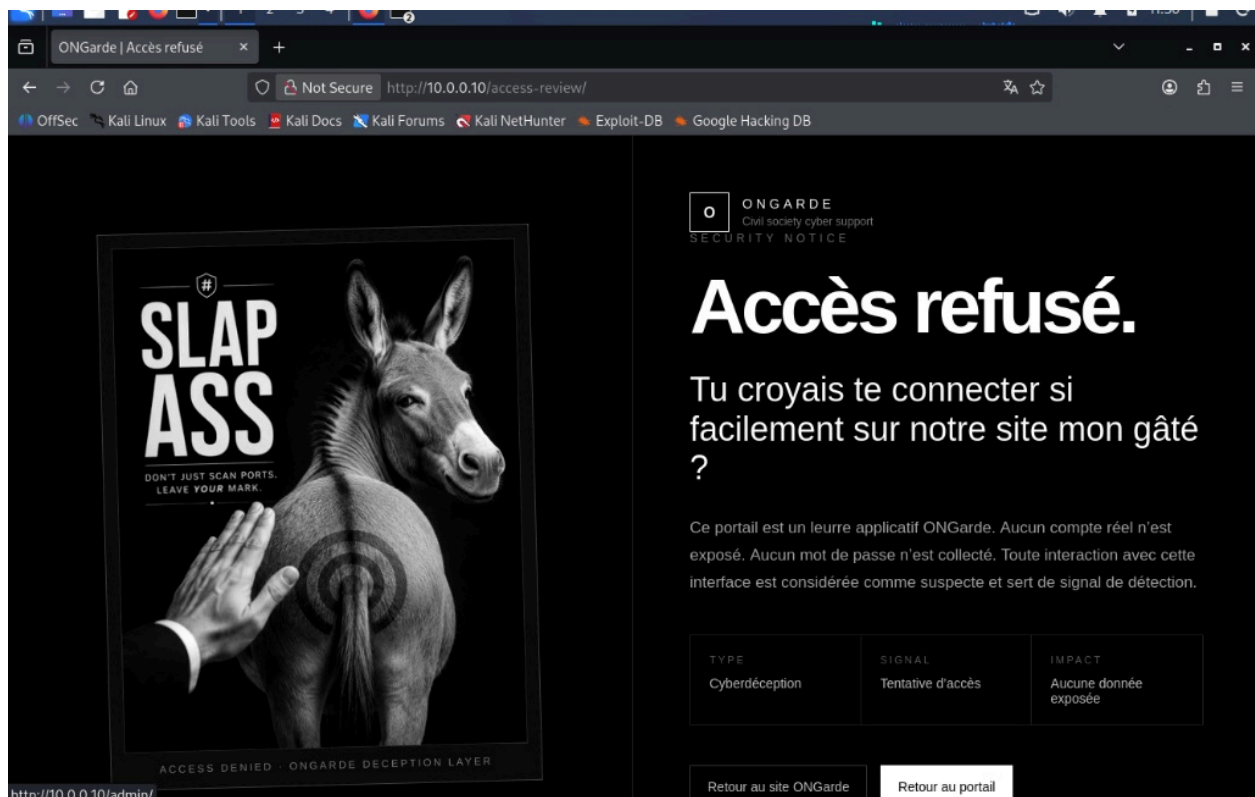
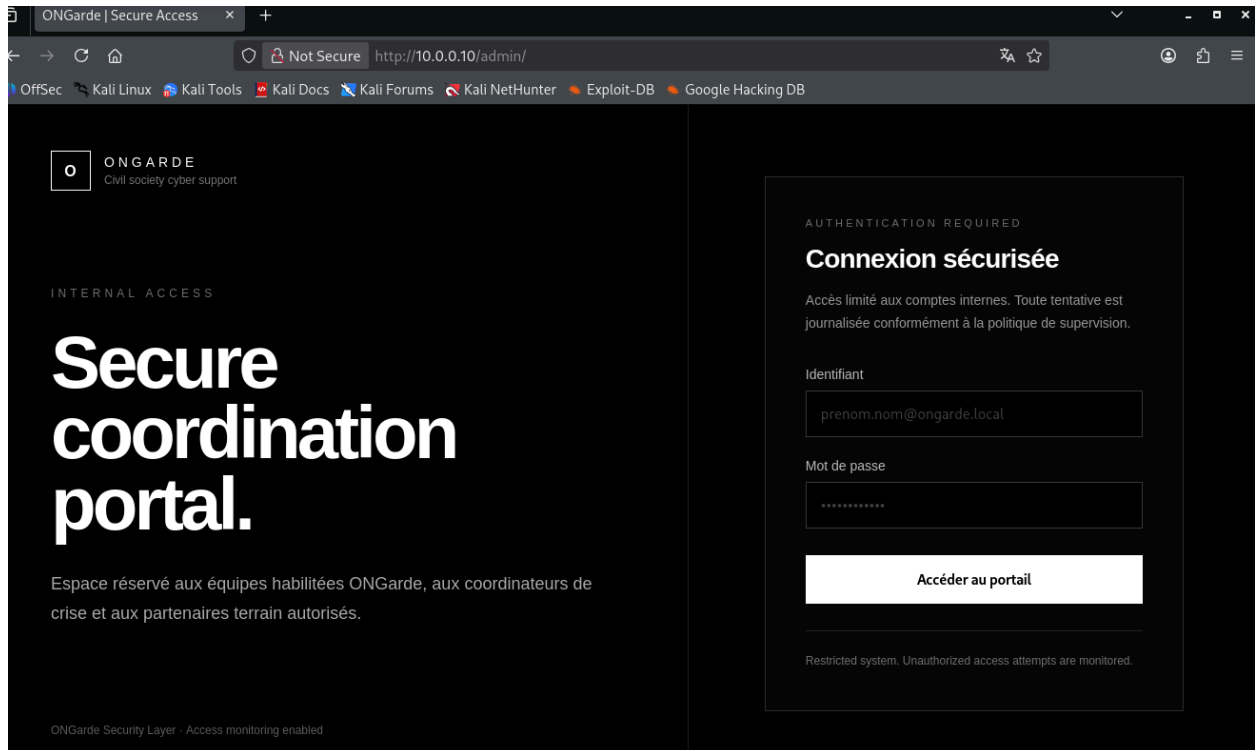
Nmap done: 1 IP address (1 host up) scanned in 67.57 seconds
```

2. Analyse et Détection du Leurre Applicatif (Port 80)

Bien que les outils de scan réseau indiquent un filtrage total, l'accès HTTP standard (port 80) permet d'afficher l'interface d'accueil de la plateforme.

A. Le faux portail de connexion (/admin/)

Une mire d'authentification apparente est accessible à l'adresse /admin/. Lors des tests d'intrusion manuels (tentatives d'injection SQL ou XSS), l'application redirige automatiquement l'utilisateur vers une page d'exclusion.



B. Preuve Technique de Cyberdception

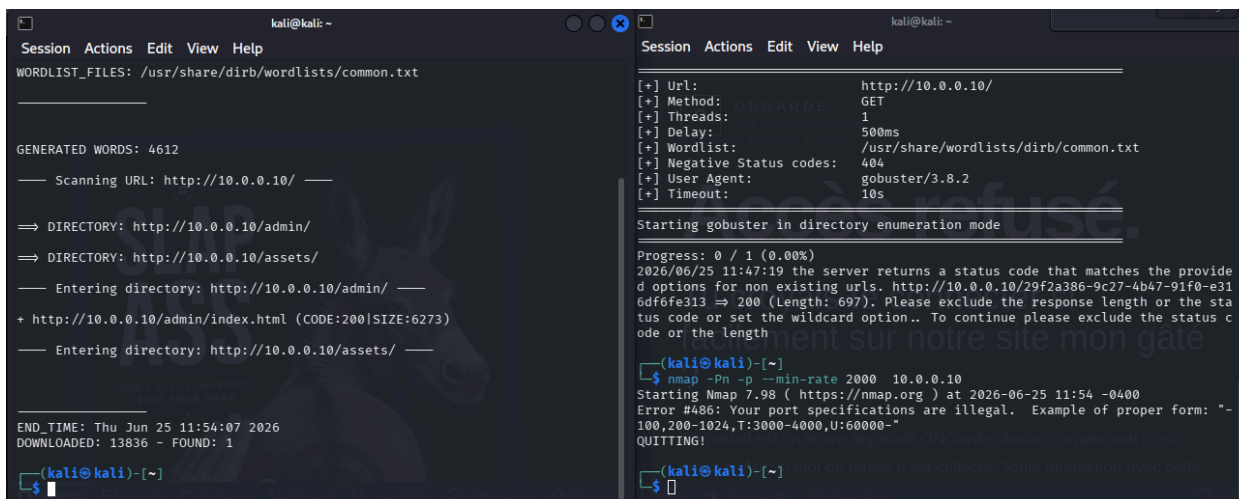
L'analyse du code source côté client (JavaScript) a révélé que ce formulaire ne communique avec aucune base de données et ne transmet aucune requête POST au serveur. Il s'agit d'une technique de **cyberdception active** (Honeypot applicatif) conçue pour tromper l'attaquant et journaliser son adresse IP.

```
<script>
  document.getElementById("login-form").addEventListener("submit", function (event) {
    event.preventDefault(); /* Leurre applicatif. Aucun mot de passe n'est transmis. Aucune
    donnée de formulaire n'est stockée. La tentative sera visible dans les logs Nginx via
    l'accès à /admin/ puis /access-review/. */ window.location.href = "/access-review/"; });
</script>
</body>
```

3. Évasion des Outils d'Énumération Standards

L'équipe de défense a déployé une configuration de type **Wildcard / Catch-all** sur son serveur web. Toutes les requêtes HTTP vers des répertoires inexistants renvoient un faux code de statut 200 OK, bloquant les outils classiques comme Gobuster.

L'utilisation de l'outil **DIRB** a permis de contourner cette mesure en analysant la taille des réponses HTTP, confirmant l'existence réelle de deux répertoires : `/admin/` et `/assets/`.



```
kali@kali: ~
Session Actions Edit View Help
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

GENERATED WORDS: 4612

Scanning URL: http://10.0.0.10/

=> DIRECTORY: http://10.0.0.10/admin/
=> DIRECTORY: http://10.0.0.10/assets/

Entering directory: http://10.0.0.10/admin/
+ http://10.0.0.10/admin/index.html (CODE:200|SIZE:6273)

Entering directory: http://10.0.0.10/assets/

END TIME: Thu Jun 25 11:54:07 2026
DOWNLOADED: 13836 - FOUND: 1

(kali@kali)-[~]
$
```

```
kali@kali: ~
Session Actions Edit View Help

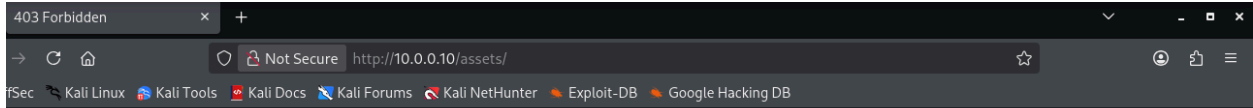
[+] Url: http://10.0.0.10/
[+] Method: GET
[+] Threads: 1
[+] Delay: 500ms
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

Progress: 0 / 1 (0.00%)
2026/06/25 11:47:19 the server returns a status code that matches the provide
d options for non existing urls. http://10.0.0.10/29f2a386-9c27-4b47-91f0-e31
6df6fe313 => 200 (Length: 697). Please exclude the response length or the sta
tus code or set the wildcard option.. To continue please exclude the status c
ode or the length

(kali@kali)-[~]
$ nmap -Pn -p --min-rate 2000 10.0.0.10
Starting Nmap 7.98 ( https://nmap.org ) at 2026-06-25 11:54 -0400
Error #486: Your port specifications are illegal. Example of proper form: "-
100,200-1024,T:3000-4000,U:60000-
QUITTING!

(kali@kali)-[~]
$
```



403 Forbidden

nginx/1.22.1

